

SGSI-UNCP

Metodología de Auditoría Basada en Riesgos y Procesos

Documento Base del Sistema de Gestión
de Seguridad de la Información

Universidad Nacional del Centro del Perú

Índice

- 1 Metodología de Auditoría Basada en Riesgos y Procesos
 - 1.1 Enfoque Estratégico
 - 1.2 Criterios de Evaluación y Priorización (Basado en Riesgo)
 - 1.3 Técnicas de Auditoría y Métodos de Muestreo
 - 1.4 Estructura del Equipo Auditor (Competencias)
 - 1.5 Flujo del Proceso de Auditoría
 - 1.6 Clasificación de Hallazgos
 - 1.7 Integración con KRIs y Auditorías No Programadas
 - 1.8 Registros de Auditoría
 - 1.9 Documentos Relacionados

1. Metodología de Auditoría Basada en Riesgos y Procesos

Organización: Universidad Nacional del Centro del Perú (UNCP) **Aprobado por:** Oficial de Seguridad y Confianza Digital **Norma:** ISO/IEC 27001:2022 (Cláusula 9.2 – Auditoría Interna) **Alineamiento:** R-SGSI-04 (Programa Maestro de Auditoría), R-SGSI-03 (Cuadro de Mando KPIs), D-SGSI-04 (Metodología de Riesgos)

1.1. Enfoque Estratégico

La UNCP abandona el modelo de auditoría estática anual por un enfoque de **Auditoría Continua y Basada en Riesgos**. El objetivo no es solo verificar el cumplimiento con ISO 27001, sino evaluar la resiliencia operativa (NIST CSF) y el valor de los activos (MAGERIT), integrando los hallazgos en el ciclo de mejora continua del SGSI.

1.1.1. 1.1 Principios Rectores

1. **Basada en Riesgos:** La frecuencia, profundidad y alcance de cada auditoría se determinan por el nivel de riesgo del proceso o activo auditado.
2. **Continua:** Se realizan micro-auditorías trimestrales en lugar de una única auditoría anual masiva.
3. **Independiente:** El equipo auditor debe ser independiente del área auditada. Cuando no sea posible la independencia interna, se contratará auditoría externa.
4. **Orientada a Evidencia:** Todas las conclusiones deben estar respaldadas por evidencia objetiva verificable (documentos, registros, entrevistas, observaciones, logs técnicos).

1.2. Criterios de Evaluación y Priorización (Basado en Riesgo)

Siguiendo la **ISO 31000**, la frecuencia y profundidad de la auditoría se determinan mediante el Nivel de Riesgo (NR) del proceso o activo, calculado según la metodología D-SGSI-04.

Nivel de Riesgo (NR)	Frecuencia de Auditoría	Tipo de Auditoría	Cobertura Mínima
Crítico (13-16)	Trimestral	Técnica: Pentesting, revisión de configuración de seguridad, análisis de vulnerabilidades, revisión de logs del SIEM	100 % de los controles aplicables
Alto (9-12)	Semestral	Operativa: Verificación de evidencias de controles, revisión de accesos privilegiados, prueba de respaldos	80 % de los controles aplicables (priorizando los de mayor riesgo)
Medio (5-8)	Anual	Administrativa: Revisión de políticas, procedimientos, registros de capacitación, actas de reuniones	60 % de los controles aplicables (muestreo representativo)
Bajo (1-4)	Bienal	Muestreo aleatorio: Verificación documental ligera	30 % de los controles aplicables (rotación en cada ciclo)

1.2.1. 2.1 Factores de Ajuste de Frecuencia

La frecuencia base puede ajustarse según: - **Madurez del proceso:** Procesos recién implementados o modificados se auditan con mayor frecuencia durante el primer año. - **Historial de hallazgos:** Procesos con no conformidades

recurrentes aumentan su frecuencia un nivel. - **Cambios significativos:** Después de un cambio mayor (migración cloud, nueva versión de ERP), se programa una auditoría adicional.

1.3. Técnicas de Auditoría y Métodos de Muestreo

1.3.1. 3.1 Técnicas de Recolección de Evidencia

Técnica	Descripción	Cuándo Aplicar
Revisión documental	Análisis de políticas, procedimientos, registros y actas	En toda auditoría; fase inicial
Entrevista	Conversación estructurada con el personal del área auditada	Para verificar comprensión y aplicación de controles
Observación directa	Presenciar la ejecución de un proceso o control en tiempo real	Controles físicos (escritorio limpio, acceso a áreas seguras)
Prueba de recorrido (walkthrough)	Seguir un transacción o proceso de principio a fin	Procesos críticos (emisión de grados, gestión de accesos)
Revisión técnica (logs)	Análisis de logs del SIEM, sistemas, firewalls, accesos	Auditorías de nivel Crítico y Alto
Análisis de herramientas	Escaneo de vulnerabilidades, revisión de configuración MDM, estado de cifrado	Auditorías técnicas
Cuestionario automatizado	Encuesta de autoevaluación enviada a los dueños de proceso	Como complemento entre auditorías presenciales

1.3.2. 3.2 Métodos de Muestreo

Cuando no sea posible auditar el 100 % de los elementos, se aplicarán los siguientes criterios de muestreo:

Tipo de Elemento	Método de Muestreo	Tamaño Mínimo
Documentos (contratos, actas, expedientes)	Muestreo estratificado por tipo y fecha	10 % del lote, mínimo 10 documentos
Usuarios con acceso privilegiado	Muestreo dirigido (todos los de alto riesgo) + aleatorio del resto	100 % de cuentas críticas + 20 % del resto
Incidentes de seguridad	100 % de los incidentes del período (población total)	Todos
Registros de capacitación	Muestreo aleatorio simple por unidad orgánica	15 % de los registros, mínimo 5 por unidad
Activos de información (inventario)	Muestreo estratificado por tipo de activo y criticidad	15 % del total, 100 % de activos críticos
Controles de la SoA	Muestreo basado en riesgo (priorizar controles de procesos críticos)	100 % de controles en procesos críticos + 40 % del resto

1.4. Estructura del Equipo Auditor (Competencias)

Rol	Certificación Recomendada	Responsabilidad
Auditor Líder	ISO 27001 Lead Auditor (IRCA/ Exemplar Global)	Diseñar el plan de auditoría; liderar el equipo; comunicarse con el CGD; emitir el informe final
Auditor Técnico	CISSP, CEH, o certificación en seguridad cloud (Huawei/ AWS/ Azure)	Validar controles técnicos: configuración de red, cloud, SIEM, vulnerabilidades
Auditor de Procesos	Conocimiento de la normativa universitaria y administrativa	Revisar procesos académicos y administrativos; verificar cumplimiento legal (Ley 29733, D.L. 1412)

Independencia: Ningún auditor puede auditar un proceso en el que haya participado durante los últimos 12 meses. Cuando no se pueda garantizar la independencia interna, se debe contratar auditoría externa.

1.5. Flujo del Proceso de Auditoría

1.5.1. 5.1 Planificación

1. El Oficial de Seguridad elabora el **Programa Maestro de Auditoría (R-SGSI-04)** con la frecuencia y alcance según la matriz de riesgos.
2. Para cada auditoría se define: objetivo, alcance, criterios, equipo auditor, cronograma y recursos necesarios.
3. Se notifica al área auditada con al menos **15 días hábiles** de anticipación (auditorías planificadas) o **5 días** (micro-auditorías trimestrales).

1.5.2. 5.2 Ejecución

1. **Reunión de apertura:** Presentación del equipo, alcance, metodología y cronograma.
2. **Recolección de evidencia:** Aplicación de las técnicas y muestreo definidos en la sección 3.
3. **Hallazgos:** Toda desviación identificada se registra como hallazgo y se clasifica según la sección 6.
4. **Reunión de cierre:** Presentación preliminar de hallazgos al área auditada.

1.5.3. 5.3 Informe y Comunicación

- El informe de auditoría debe emitirse dentro de los **10 días hábiles** posteriores a la ejecución.
- Contenido mínimo del informe: resumen ejecutivo, alcance, metodología, hallazgos detallados, clasificación, conclusiones y recomendaciones.
- El informe se presenta al Comité de Gobierno Digital y al dueño del proceso auditado.

1.5.4. 5.4 Seguimiento de No Conformidades

1. El área auditada debe elaborar un **Plan de Acción Correctiva** en el formato **F-SGSI-04 (RAC)** dentro de los **15 días hábiles** siguientes al informe.
2. El Oficial de Seguridad realiza el seguimiento de la implementación de las acciones.
3. Se programa una **verificación de eficacia** dentro de los 3 meses posteriores al cierre del RAC.
4. Si la acción correctiva no es eficaz, se escala al Comité de Gobierno Digital.

1.6. Clasificación de Hallazgos

Tipo	Definición	Acción Requerida
Conformidad	El control o proceso cumple con los requisitos auditados	Reconocimiento y mantenimiento
Oportunidad de Mejora (OM)	El control cumple pero puede optimizarse	Recomendación; no requiere RAC formal
No Conformidad Menor (NC Menor)	Incumplimiento puntual que no compromete la eficacia del SGSI; desviación aislada	RAC con plazo máximo de 30 días
No Conformidad Mayor (NC Mayor)	Incumplimiento generalizado o sistemático; ausencia total de un control requerido; riesgo no mitigado	RAC con plazo máximo de 15 días; escalamiento al CGD

Tipo	Definición	Acción Requerida
Observación	Situación que, sin ser un incumplimiento, podría derivar en uno si no se corrige	Comunicación formal; seguimiento en próxima auditoría

1.7. Integración con KRIs y Auditorías No Programadas

Cuando los **KRIs (Key Risk Indicators)** definidos en el R-SGSI-03 superen los umbrales críticos, se podrá activar una **auditoría no programada**:

KRI	Umbral Crítico	Auditoría Disparada
Intentos de acceso fallidos	> 10 intentos/minuto sostenido por 1 hora	Revisión de cuentas y políticas de bloqueo
Alertas de malware no resueltas	> 5 alertas sin atender en 24 horas	Auditoría técnica de detección y respuesta
Caída de servicio crítico	Tiempo de inactividad > RTO definido	Revisión post-mortem del incidente + auditoría de continuidad
Nuevas vulnerabilidades críticas	CVE con CVSS >= 9.0 en sistemas UNCP	Auditoría de parcheo y gestión de vulnerabilidades

1.8. Registros de Auditoría

Documento	Código	Tiempo de Retención
Programa Maestro de Auditoría	R-SGSI-04	5 años
Plan de Auditoría	Plantilla-Plan-Auditoria	5 años
Lista de Chequeo	Plantilla-Lista-Chequeo-Auditoria	5 años
Informe de Auditoría	Plantilla-Informe-Auditoria	5 años
Reporte de Acción Correctiva (RAC)	F-SGSI-04	5 años después del cierre
Acta de Revisión por la Dirección	Plantilla-Revisión-por-la-Dirección	5 años

1.9. Documentos Relacionados

Código	Nombre
R-SGSI-04	Programa Maestro de Auditoría (Ciclo 2026)
R-SGSI-03	Cuadro de Mando de Seguridad (KPIs)
D-SGSI-04	Metodología de Evaluación y Tratamiento de Riesgos
D-SGSI-05	Declaración de Aplicabilidad (SoA)
F-SGSI-04	Reporte de Acción Correctiva (RAC)
Plantilla-Plan-Auditoria	Plan de Auditoría Interna del SGSI
Plantilla-Lista-Chequeo-Auditoria	Lista de Chequeo de Auditoría ISO 27001:2022
Plantilla-Informe-Auditoria	Informe de Auditoría Interna del SGSI